Traffic Management System - Security Requirements

Req ID	Security Area	Description	Priority	Acceptance Criteria	Rationale	Comments
SR-01	Authentication	The system shall authenticate registered users before granting access to protected features.	High	Pass: Valid credentials allow access and invalid credentials are rejected. Fail: An unauthenticated or invalid user gains access to a protected feature.	Prevents unauthorized access to user and system functions.	
SR-02	Role-Based Access	The system shall restrict administrator, signal-control, incident-management, report-generation, and emergency functions to authorized roles.	High	Pass: Each restricted function is available only to its authorized role. Fail: A user without the required role can access or perform the function.	Enforces the role-based access requirement in the SRS.	
SR-03	Password Protection	The system shall store passwords securely and shall not store them in plain text.	High	Pass: Stored password data is protected and cannot be read as plain-text passwords. Fail: Plain-text passwords are stored or exposed.	Reduces the risk of password disclosure if stored data is accessed.	
SR-04	Session Protection	The system shall protect authenticated sessions against unauthorized use.	High	Pass: Protected features require a valid authenticated session and access is denied when the session is invalid. Fail: An invalid session can access protected features.	Protects accounts after authentication.	
SR-05	Input Validation	The system shall validate user-supplied input before processing registration, login, incident reports, route requests, and administrative changes.	High	Pass: Invalid input is rejected or handled safely without corrupting stored data or bypassing access controls. Fail: Invalid input causes unsafe processing, data corruption, or unauthorized actions.	Supports the SRS reliability requirement and reduces misuse of input fields.	
SR-06	Signal-Control Authorization	The system shall permit traffic-signal status changes only by authorized administrators and shall validate each requested change.	High	Pass: An authorized and valid change is accepted; unauthorized or invalid changes are rejected. Fail: An unauthorized or invalid signal change is applied.	Protects a safety-relevant administrative function.	
SR-07	Audit Logging	The system shall log important administrative actions, including signal changes, incident updates, and alert creation, with relevant action and time information.	High	Pass: Each specified administrative action creates a traceable log entry with action and time information. Fail: A required action is not recorded or cannot be traced.	Supports the SRS audit logging and auditability requirements.	
SR-08	Personal Data Privacy	The system shall collect only necessary user information and protect personal and location-related data.	High	Pass: Only information needed for system functions is collected and personal/location-related data is protected from unauthorized access. Fail: unnecessary information is collected or protected data is exposed.	Reflects the SRS privacy requirement.	
SR-09	Data Integrity	The system shall maintain consistent and accurate records for users, traffic events, incidents, alerts, routes, parking data, signal states, and administrative actions.	High	Pass: Supported operations preserve accurate and consistent records. Fail: Records become inconsistent, inaccurate, or are changed without authorization.	Protects the reliability of traffic and administrative information.	
SR-10	Error Handling	The system shall handle invalid requests and processing errors without exposing protected data or corrupting stored records.	Medium	Pass: Errors are handled safely and records remain intact; error responses do not disclose protected information. Fail: An error exposes protected data or corrupts records.	Limits information exposure and supports reliable operation.	
SR-11	Protected Function Access	The system shall deny access to protected functions and data when a user is not authenticated or lacks the required permission.	High	Pass: Requests without authentication or the required role are denied. Fail: A restricted request succeeds without the required access.	Provides a consistent access-control rule across the application.	
SR-12	Security Verification	The system shall be tested to verify authentication, role-based access, session protection, input validation, and audit logging.	Medium	Pass: Tests demonstrate that the listed security controls work as specified. Fail: A test reveals that a required control can be bypassed or does not operate as expected.	Provides evidence that the documented security requirements are implemented.	